Matriz de Ciberseguridad Alta, Cambio y Baja

Matriz de responsabilidades (RACI)

Organización: Una institución educativa (universidad), el departamento de TI / Servicios Informáticos.

Etapa	Actividad	Recursos Humanos	Jefe de TI	Admin. de Sistemas	Seguridad de la Información	Soporte Técnico	Jefe inmediato	Auditoría Interna
ALTA	Checar antecedentes de la persona antes de darle acceso a nada (background check)	**R/A**	I		I			
	Firmar contrato de confidencialidad	**R/A**	**R**		C			
	Darle solo los privilegios necesarios			**R**	**R/A**		C	
	Un admin recibe permisos especiales		C	**R**	**A**			I
	Meterlo a los grupos que correspondan según su rol (RBAC)			**R**	**A**		C	
	Entregar equipo ya con disco cifrado y antivirus/EDR instalado, no después		**A**		C	**R**		
	Capacitación básica de seguridad	C			**R/A**		I	
	Dejar registrado el alta en la bitácora de accesos, para cuando alguien pregunte			C	**R/A**			I
	Documentar exactamente qué accesos tiene y con qué nivel		**R/A**	C	I			
CAMBIO	Pedir el cambio de acceso por escrito, justificando por qué lo necesita el nuevo rol	I	I		I		**R/A**	
	Revisar y autorizar el cambio de privilegios		I	C	**R/A**		C	
	Quitar los accesos que ya no le tocan con el nuevo rol, para evitar que se acumulen privilegios de más			**R**	**A**		C	
	Darle solo los accesos nuevos que realmente necesita para el rol nuevo			**R**	**A**		C	
	Actualizar sus grupos en el directorio activo / IAM			**R**	**A**			
	Ver si necesita equipo o tokens distintos por el cambio		**A**		C	**R**	C	
	Actualizar la documentación de accesos		**A**	C	**R**			I
	Avisar del cambio a los sistemas y responsables que le afecten		**R/A**	I	I		I	
	Si el nuevo rol maneja datos más sensibles, capacitarlo de nuevo	I			**R/A**		C	
BAJA	Avisar de inmediato a TI/Seguridad de la baja, el mismo día	**R/A**	I	I	I	I		
	Revocar todas sus cuentas	I		**R**	**A**			
	Cambiar contraseñas de cuentas compartidas o de servicio a las que tenía acceso		I	**R**	**A**			
	Recuperar el equipo físico: laptop, tokens, credenciales	C	**A**		I	**R**		
	Respaldar y transferir lo que sirva de su trabajo antes de borrar todo			**R**	C		**R/A**	
	Desactivar el correo y archivarlo/reenviarlo según la política		**A**	**R**			C	
	Registrar la baja en la bitácora de auditoría con fecha y hora exactas			C	C			**R/A**
	Entrevista de salida y recordarle que la confidencialidad sigue aplicando aunque ya se vaya	**R/A**			C			

Simbología

R	Responsable: ejecuta la actividad	**A**	Aprueba / rinde cuentas (solo uno por actividad)	**R/A**	Ejecuta y además aprueba	**C**	Consultado: se le pide información antes	**I**	Informado: se le avisa el resultado